COTEJO

Programa de auditoría con verificación automatizada de controles

Sistema auditado: **Rastro**

Sergio Montoya · Nicolás Torres · Oscar Rincón
Auditoría de Sistemas (ISD39) · Grupo 30112



El problema y el sistema auditado

> **Un control declarado no es un control verificado.**

Sistema auditado. Rastro, trazabilidad de envíos en AWS `us-east-1`: ocho funciones, tres tablas, almacén cifrado y registro de actividad. **Lo construimos nosotros**, en Cloud Computing.

Lo comprobamos antes de construir nada:

La configuración dice	El sistema hace
Autoriza a cualquier principal	Rechaza **toda** invocación

Un auditor que solo lee configuraciones habría reportado un hallazgo falso.



BLOQUE 2 · PLANIFICACIÓN

Objetivo, alcance y plan

Objetivo. Verificar de forma automatizada y reproducible los controles de un sistema desplegado, con papeles de trabajo trazables a un marco.

Alcance: diez controles sobre infraestructura, aplicación, bitácora y secretos.
Fuera: proceso de desarrollo, código fuente, intrusión y otros sistemas.

Fase	Semanas	Responsable
Planeación y catálogo	1–3	Oscar Rincón
Diseño del programa	4–5	Sergio Montoya
Construcción	6–9	Nicolás Torres
Ejecución y comunicación	10–12	Oscar Rincón

Independencia interna: quien construyó un componente de Rastro no ejecuta ni evalúa sus pruebas.
Sin costo adicional. No logrado: retención inmutable del almacén de papeles.

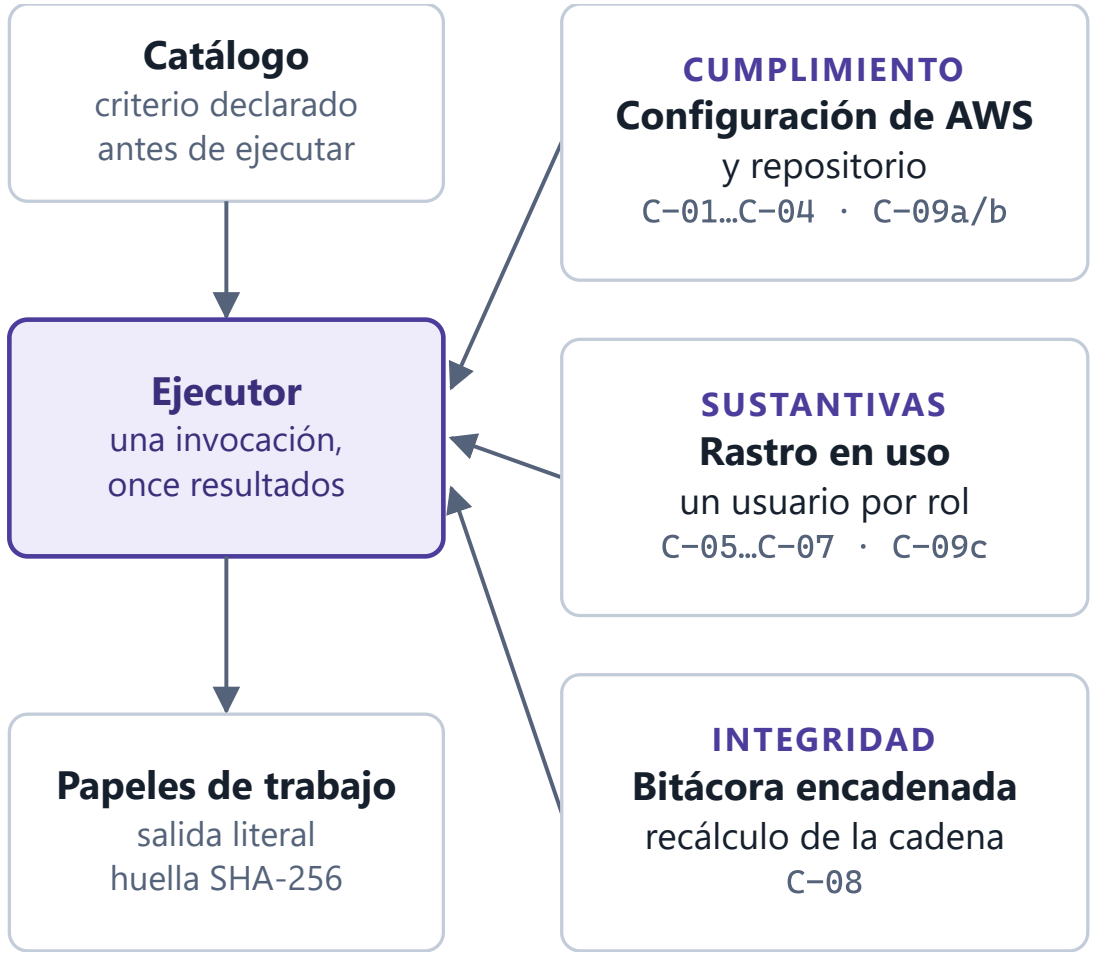
Metodología y técnicas

Secuencia **ITAF** (ISACA): planeación → programa → ejecución → comunicación.

El criterio se declara antes de ejecutar la prueba.

BIEN	Se probó y cumplió el criterio
MAL	Se probó y no cumplió: hallazgo
SIN REVISAR	No se pudo probar: **no aprobado**

Sin entrevistas: el objeto es un sistema, no un proceso humano.



Amenazas y controles

Amenaza	Prob.	Impacto	Control
Acceso a datos de otra organización	Media	Muy alto	Clave de partición por organización · C-06
Alteración del histórico	Baja	Muy alto	Bitácora encadenada · C-08
Operación por rol no autorizado	Media	Alto	Autorización en capa común · C-05
Exposición de secretos	Media	Muy alto	C-09a, C-09b, C-09c
Evidencias legibles por terceros	Baja	Alto	Cifrado y bloqueo público · C-02, C-03

Activo que suele olvidarse: los papeles de trabajo, porque enumeran las debilidades.
Faltan, porque el entorno lo impide: rol por función, credenciales de solo lectura para el auditor y ancla de integridad externa.

Roles y segregación de funciones

Rol	Puede	No puede
Administrador	Todo: envíos, catálogos, cuentas y roles	**Leer la bitácora**
Coordinador	Despachar, reanudar incidencias, editar catálogos	Administrar cuentas
Despachador	Crear y asignar envíos, registrar eventos	Reanudar incidencias
Conductor	Ver **sus** envíos, marcar avance, cargar evidencia	Crear o asignar envíos
Auditor	Consultar y **leer la bitácora**	Cualquier escritura

C-05 comprueba una celda: un conductor que intenta crear un envío recibe 403 y queda registrado.
Fuera de la aplicación, las funciones y el propio auditor usan un rol amplio: H-PERM-01 y H-PERM-02.

BLOQUE 5 · NORMATIVAS

Normativas y cumplimiento

Marco	Qué aporta	Control
COBIT 2019, DSS05 y DSS06	Seguridad y control de procesos	C-05, C-06, C-07
ITAF	Evidencia suficiente y confiable	Estructura del informe
ISO/IEC 27001:2022	Criptografía, copias, autenticación	C-02, C-04, C-09
CIS AWS Benchmark	Configuración segura de la cuenta	C-01, C-03
OWASP Top 10:2021 A01	Control de acceso deficiente	C-05, C-06
NIST SP 800-92 y 800-57	Registros y compromiso de llaves	C-01, C-09c

11
resultados

10
conformes

1
desviado

0
sin ejecutar

Hallazgos

H-01 · Condición	Un secreto de firma permanece en el historial, fuera del árbol actual
Criterio	ISO/IEC 27001 A.5.17 y A.8.4 · CWE-798
Causa	Se versionó; retirar el archivo no lo saca del historial
Riesgo	Severidad media: el secreto ya fue invalidado
Recomendación	Reescribir el historial

H-PERM-01 · Mínimo privilegio — alta. Las ocho funciones comparten un rol amplio.
H-PERM-02 · Privilegios del auditor — media. El programa puede escribir sobre lo que audita.



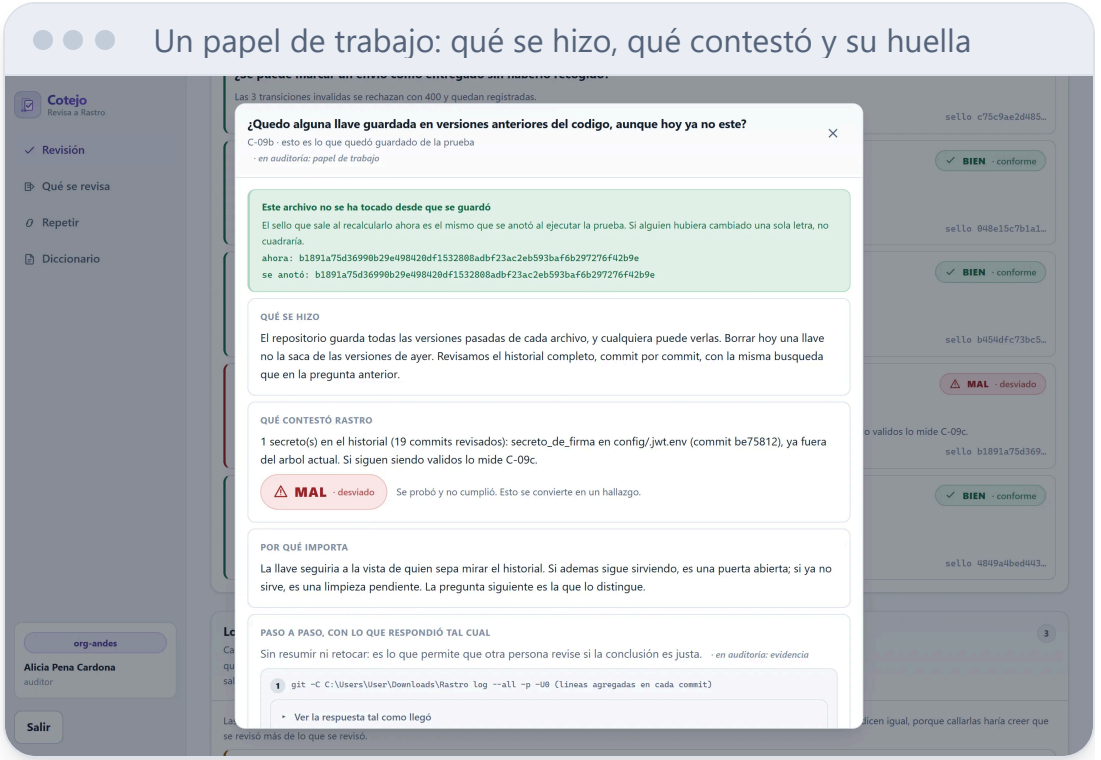
BLOQUE 6 · HALLAZGOS Y EVIDENCIAS

También nos auditamos

El incidente. Publicamos un secreto de firma durante **27 minutos**. Lo vimos al revisar el despliegue, no con Cotejo: **ningún control del catálogo cubría los secretos**. Añadimos C-09.

El error de método. El control de cifrado dijo MAL con el almacén vacío. Lo correcto era SIN REVISAR.

Cada papel de trabajo conserva: procedimiento · salida literal · marca de tiempo · identidad · huella SHA-256.



Conclusiones y mejoras

- Once controles evaluados, **ninguno sin ejecutar**; diez conformes, uno desviado
- En dos ejecuciones, diez controles **se repiten igual**
- 34 pruebas del propio programa, dentro de una suite de 234 en verde

Acción inmediata	Responsable	Tiempo
Partir el control de cifrado en dos	Oscar Rincón	4 horas
Validación en doble sentido de cumplimiento	Nicolás Torres	1 semana

Limitaciones: auditamos lo que construimos · solo se verifica el catálogo · el ejecutor puede escribir sobre lo que audita.